

Security Policy — TechNova Solutions

Authentication Rules

- JWT must be verified on every request using RS256 algorithm
- Access tokens expire after 15 minutes
- Refresh tokens expire after 7 days
- Token refresh must happen before expiry
- Concurrent session limit: 3 devices per user

Password Policy

- Minimum 8 characters
- Must include uppercase letter and number
- Special characters recommended
- Password history: last 5 passwords cannot be reused
- Account lockout after 5 failed attempts (30 min lock)

API Security

- Rate limiting: 100 requests per minute per IP
- IP blocking after 5 failed authentication attempts
- All endpoints require HTTPS
- CORS configured for allowed origins only
- Input validation on all endpoints (DTO validation)
- SQL injection prevention via parameterized queries

Data Protection

- PII data encrypted at rest (AES-256)
- TLS 1.3 for data in transit
- Database backups every 6 hours
- Retention period: 7 years for financial data, 3 years for logs

Incident Handling

- All security incidents must be reported within 24 hours
- Incident response team: security@technova.io
- Severity levels: P1 (critical), P2 (high), P3 (medium), P4 (low)
- P1 incidents: all hands on deck, CEO notified
- Post-incident review required within 48 hours

Compliance

- SOC 2 Type II certified
- GDPR compliant for EU users
- Annual penetration testing
- Quarterly security audits